

Warsaw, December 20, 2023

## Decision

DKN.5131.34.2022

Based on Article 104 § 1 of the Act of June 14, 1960, the Code of Administrative Procedure (Journal of Laws of 2023, item 775, as amended), Article 7 paragraphs 1 and 2, as well as Article 60, Article 102 paragraph 1 point 1 and paragraph 3 of the Act of May 10, 2018, on the protection of personal data (Journal of Laws of 2019, item 1781), and also Article 57 paragraph 1 letters a) and h), Article 58 paragraph 2 letter i), Article 83 paragraphs 1 and 2, Article 83 paragraph 4 letter a) in connection with Article 24 paragraph 1, Article 25 paragraph 1, and Article 32 paragraphs 1 and 2, as well as Article 83 paragraph 5 letter a) in connection with Article 5 paragraph 1 letter f) and Article 5 paragraph 2 of the Regulation of the European Parliament and of the Council (EU) 2016/679 of April 27, 2016, on the protection of natural persons in relation to the processing of personal data and on the free movement of such data, and repealing Directive 95/46/EC (General Data Protection Regulation) (OJ EU L 119 of 05.04.2016, p. 1, OJ EU L 127 of 23.05.2018, p. 2, and OJ EU L 74 of 04.03.2021, p. 35), after conducting an ex officio administrative proceeding regarding the violation of personal data protection regulations by the Mayor of the Municipality of Nowiny (Municipal Office of Nowiny, ul. Białe Zagłębienie 25, 26-052 Nowiny), the President of the Personal Data Protection Office, stating that the Mayor of the Municipality of Nowiny (Municipal Office of Nowiny, ul. Białe Zagłębienie 25, 26-052 Nowiny) violated the provisions of Article 5 paragraph 1 letter f), Article 5 paragraph 2, Article 24 paragraph 1, Article 25 paragraph 1, and Article 32 paragraphs 1 and 2 of the Regulation of the European Parliament and of the Council (EU) 2016/679 of April 27, 2016, on the protection of natural persons in relation to the processing of personal data and on the free movement of such data, and repealing Directive 95/46/EC (General Data Protection Regulation) (OJ EU L 119 of 05.04.2016, p. 1, OJ EU L 127 of 23.05.2018, p. 2, and OJ EU L 74 of 04.03.2021, p. 35), hereinafter referred to as Regulation 2016/679, consisting of the Mayor of the Municipality of Nowiny's failure to implement appropriate technical and organizational measures to ensure a level of security appropriate to the risk of data processing, in particular regarding the implementation of the ability to continuously ensure the confidentiality, integrity, availability, and resilience of processing systems and services, as well as the ability to quickly restore the availability of personal data and access to it in the event of a physical or technical incident, which results in a violation of the principle of integrity and confidentiality and the principle of accountability, imposes on the Mayor of the Municipality of Nowiny (Municipal Office of Nowiny, ul. Białe Zagłębienie 25, 26-052 Nowiny) for the violation of the provisions of Article 5 paragraph 1 letter f), Article 5 paragraph 2, Article 25 paragraph 1, and Article 32 paragraphs 1 and 2 of Regulation 2016/679 an administrative fine in the amount of 50,000 Polish zlotys (in words: fifty thousand zlotys).

## Justification

The Mayor of the Municipality of Nowiny (Municipal Office of Nowiny, ul. Białe Zagłębienie 25, 26-052 Nowiny), hereinafter referred to as the Mayor or Administrator, on December 13, 2021, reported to the President of the Personal Data Protection Office, hereinafter also referred to as the President of UODO or the supervisory authority, a personal data breach that occurred on December 9, 2021. On December 14, 2021, the Administrator sent a supplementary notification, in which he described the nature of the personal data breach. In the supplementary form, the Mayor indicated that "(...) on (...)11.2021 at approximately 3:00 PM, the IT service of the Municipal Office of Nowiny detected the encryption of the server on which the database of the H. program by Z. was located, which was used to perform tasks related to the personnel and financial service of the Office. An incident reporting procedure was conducted to CERT NASK in accordance with the provisions resulting from the Act of July 5, 2018, on the national cybersecurity system. During the verification of the event, it was established that an employee of the Municipal Office of Nowiny opened an infected link, which resulted in the activation of the ransomware X. malware that encrypted the server. Subsequently, on (...)12.2021 at 1:27 PM, the Administrator received information from the CERT Poland | CSIRT NASK operator regarding a data leak from the resources of the Municipal Office of Nowiny, which was made public by unknown perpetrators at (...). The ransomware X allows direct access to the administrator

panel in the system (...), which was directly exploited by the attackers. During further explanatory actions on (...).12.2021 at approximately 9:00 AM, the Administrator received confirmation of the leak of four databases containing personal data of current and former employees of the Municipal Office of Nowiny. From the explanatory actions carried out by the IT service of the Municipal Office of Nowiny and specialists from CERT NASK, it was found that the server was infected with the malware X. After that, there was a leak of personal data of current and former employees of the Office and the public disclosure of the stolen data at the address: [http://\(...\)](http://(...)). The IT service of the Municipal Office managed to restore the data concerning the resources collected on the server to the date of (...) September 2019. From (...) September 2019 until the time of the attack, i.e., on (...).11.2021, all data stored on the server was lost. The backup copy of the data was stored on the server that was attacked and was encrypted. This server also contained data processed by G. collected in the K. program. January 2022 was conducted by an external entity, and the results indicated that there were no significant deficiencies in the security measures implemented by the Administrator.”

IV. In the letter dated June 10, 2022, the Administrator stated that “the incident was reported to the relevant authorities, and the necessary steps were taken to mitigate the effects of the breach.”

V. The President of UODO, after conducting the explanatory proceedings regarding the reported breach of personal data protection and the administrative proceedings, established the following factual state.

1. The Administrator confirmed that the breach occurred on November (...) 2021, and it was reported to the supervisory authority on December 13, 2021.

2. The Administrator indicated that the cause of the delay in action was due to “unprofessional behavior” of an employee at the Urząd Gminy Nowiny, who, in the opinion of the Administrator, “downplayed the significance of the incident.”

3. To obtain additional information regarding the monitoring by the Administrator and the data protection officer of the performance of duties by the Urząd Gminy Nowiny, the supervisory authority requested, in a letter dated May 17, 2022, the submission of appropriate explanations and evidence to confirm them.

4. In response, the Administrator, in a letter dated May 31, 2022, explained that “the performance of duties by the Urząd Gminy Nowiny was monitored through annual information security audits. The audit reports for 2020 and 2021 were provided to you in the letter marked: [...] dated January 10, 2022. The audit for January 2022 was conducted by an external entity, and the results indicated that there were no significant deficiencies in the security measures implemented by the Administrator.”

VI. The President of UODO, based on the findings from the explanatory proceedings, determined that the Administrator failed to fulfill the obligations arising from the provisions of Article 5(1)(f), Article 5(2), Article 24(1), Article 25(1), and Article 32(1) and (2) of Regulation 2016/679.

VII. Consequently, the President of UODO decided to impose an administrative fine on the Administrator for the breach of personal data protection regulations.

VIII. The fine was determined based on the severity of the breach, the number of individuals affected, and the potential risks to the rights and freedoms of the data subjects involved.

IX. The Administrator has the right to appeal against the decision of the President of UODO in accordance with applicable law.

X. This decision is final and may be subject to judicial review.

Date: [Insert Date]

Signature: [Insert Signature]

Title: [Insert Title]

Office: [Insert Office]

2020 revealed a number of deficiencies that ultimately were not rectified despite the employee's assurances, as indicated by the audit data for 2021. The behavior (...) raised concerns also during the

ongoing provision of work by (...) . Specific doubts concerned the lack of any response to the verbal and subsequently written orders to note down and deposit all passwords necessary for the full administration of the network. These passwords were not made available contrary to the order to the employee on (...) April 2021. Only the occurrence of an incident allowed for almost forced enforcement of the order. Attached is a photocopy of the correspondence and documentation in this regard (...).

IV. The Administrator provided explanations regarding the risk analysis and attached a copy of the "Analysis (...)" from the Municipality of Nowiny, prepared in May 2021, additionally stating that "(...) I indicate that the Administrator, upon discovering a data protection breach, reported it to the supervisory authority within the timeframe referred to in Article 33(1) of the GDPR, as he assessed the risk of infringement of the rights or freedoms of natural persons as high [which he justified in the report]. Therefore, it is not possible to provide the risk analysis on the basis of which no high risk was identified, as the Administrator does not possess such a document (...)". It should be noted that in the report of the personal data breach submitted on December 13, 2021, to the supervisory authority, in point 8B of the reporting form, the Administrator indicated that there was no high risk of infringement of the rights or freedoms of natural persons, whereas in the supplementary report of December 14, 2021, the Administrator, in point 8B of the reporting form, indicated that there was a high risk of infringement of the rights or freedoms of natural persons. Furthermore, the Mayor provided an analysis conducted after the personal data breach. The risk analysis conducted before the occurrence of the personal data breach was prepared in May 2021 by an external entity (C.) and accepted by the Mayor. The submitted document states that "(...) the risk analysis report was prepared based on an interview with (...), which took place on May 4, 2021 [the date postponed at the request of (...) dated April 28, 2021] and an audit (...). All conclusions and recommendations and the results of the risk assessment were communicated during the interview (...)". The risk analysis submitted prior to the occurrence of the personal data breach identifies threats to security in the process of processing personal data related to the use of IT systems. The Administrator assessed risks for: - the network, - the IT system and its informational resources, - access workstations. As part of the assessment of the aforementioned risks, categories of threats were defined and specific threats assigned to them. Below, these risks (indicated in the submitted analysis conducted by the Administrator), which are crucial from the perspective of this case, will be described. In the risk assessment for the network, among other things, the following categories of threats were indicated: - (...) In the risk assessment for the teleinformatics system and its informational resources, among other things, the following categories of threats were indicated: 1) (...) In the risk assessment for access workstations, among other things, the following categories of threats were indicated: - (...)

V. The Mayor provided explanations regarding the breach of data availability, attempts to recover access to encrypted data, and the execution of backup copies. In a letter dated January 10, 2022, the Administrator explained that on December 6, 2021, he restored encrypted data "as of September 2019." In response to the request from the supervisory authority (formulated in the letter from the President of the UODO dated December 13, 2021) for the procedure for creating backup copies in the City Office of Nowiny functioning before the personal data breach and indicating whether it was subject to changes due to the breach, the Administrator explained that "(...) they are performed daily and stored on (...). Entire server instances are archived. (...) The above constitutes the implementation of the procedure for storing copies and mechanisms for storing copies on external IT media outside the working infrastructure, resulting from the security audit conducted in 2021 - Chapter "...", page (...) - protocol submitted as Attachment No. (...). The applicable Security Policy will be fully (not only in this regard) verified and updated. Currently, the procedure, which is no longer applied following the audit findings, is defined in Attachment (...) (...)". In a letter dated February 16, 2022, the Administrator provided additional explanations regarding the execution of backup copies and data recovery, indicating that "(...) Data was restored from backup copies as of September 2019 due to the failure of (...) to fulfill basic employee obligations in this regard. The applicable rules for creating backup copies for the data affected by the attack were not followed by (...). The last copy created as of September 2019 was transferred to (...). Incremental copies from September 2019 were created daily; however, they were stored on the infected server, and as a result, they were encrypted along with the other data

(...) Until the occurrence of the incident, the possibility of restoring backup copies was not tested (...). The Administrator further explained that the anticipated date for restoring personal data from the paper version is the end of Q3 2022. In this regard, the Administrator provided additional explanations in a letter dated March 3, 2022, indicating that "(...) The Municipality can fulfill all imposed obligations.

**\*\*VI.\*\*** In response to the inquiry from the supervisory authority regarding whether the Administrator conducted training for the employees of the Nowiny Commune Office on cybersecurity and the use of social engineering tools, the Mayor indicated in a letter dated January 10, 2023, that training for employees on cybersecurity was conducted on December 1, 2021. The President of the Personal Data Protection Office (UODO) requested additional clarifications in this area. In a letter dated July 5, 2023, the supervisory authority asked the Mayor to indicate whether, prior to the occurrence of the personal data breach, the Administrator had conducted training for the employees of the Nowiny Commune Office on cybersecurity and the use of social engineering tools (phishing), and if so, requested the submission of written evidence of their completion. In response to the above, the Mayor indicated in a letter dated July 13, 2023, that "(...) one of the reasons for terminating the contract for the role of Data Protection Officer (IOD) and oversight of compliance with data protection regulations with the service provider V. as of (...) October 2021, was the fact that no training on personal data protection, including the protection of data processed in IT systems, had been conducted. The new IOD, who has been in office since (...) October 2021, conducted the required training on (...) October 2021. Attached is the attendance list and sample certificates included in the employees' personal files. Issues related to cybersecurity and the use of social engineering tools were discussed within the thematic block "Data Processing Security (...)". Along with the explanations, the Mayor attached the "Statement (...) " indicating the lack of conducted training, the attendance list for the training on (...) October 2021, and sample certificates issued to the training participants.

**\*\*VII.\*\*** In a letter dated January 10, 2022, the Administrator further explained that an annual audit of the state of information processing security is conducted. The Mayor attached the protocols from the audits for the years 2020 and 2021. Subsequently, in a letter dated February 16, 2022, the Administrator provided explanations regarding the audit conducted after the identification of the personal data breach, indicating that it is currently being carried out – the Mayor committed to sending the relevant protocol upon completion of the work. The "Report (...)" was submitted to the supervisory authority as an attachment to the Administrator's letter dated May 31, 2022. The information security audit conducted from (...) February 2020 to (...) March 2020 by an external auditor (which constitutes attachment no. (...) to the letter dated January 10, 2022) presents a number of significant pieces of information regarding the state of security of the Administrator's IT system. As indicated by the authors of the audit report (document reference (...)), its purpose was "(...) to present the state of information security observed by the auditors in the unit and to indicate any vulnerabilities affecting the processed data. The audit was conducted in terms of compliance with applicable legal regulations regarding information processing and good practices and security standards (...)". The auditors described the factual state of security of the IT system, noting a number of irregularities and – in relation to most identified irregularities – proposed recommendations for their elimination. Among the identified irregularities are those that had a direct or indirect impact on the occurrence of the personal data breach reported to the supervisory authority on December 13, 2021. The submitted report indicated, among other things: 1. (...)

The information security audit conducted from (...) November 2021 to (...) November 2021 by an external auditor (which constitutes attachment no. (...) to the letter dated January 10, 2022) presents a number of significant pieces of information regarding the state of security of the Administrator's IT system. The purpose of the aforementioned audit was identical to the purpose of the control that was conducted from (...) February 2020 to (...) March 2020. The conclusions of the two aforementioned audits are similar – the submitted audit report, which took place from (...) November 2021 to (...) November 2021, indicated, among other things: 1. (...)

Furthermore, the report from the information security audit conducted from (...) to (...) November 2021 contained recommendations related to the overall state of the IT infrastructure, indicating: 1) (...)

On the other hand, in the document titled "Report (...)", which is an attachment to the Administrator's letter dated May 31, 2022, it was indicated that "(...) The post-breach analysis conducted by the company S. at the request of the Nowiny Commune Office was based on the "diamond model". This model, in addition to analyzing a single event, allows for linking different attacks to each other by isolating similar attack techniques and identifying the malicious software used. After applying the diamond model, the following was determined: After the security audit at the Nowiny Commune Office, which took place on (...) November 11, 2021, the security measures implemented on the servers that the employees of the Commune Office connected to were checked. After... conducted analysis revealed that (...)"

VIII. The Mayor provided explanations regarding the actions taken to mitigate the risk of a recurrence of a similar personal data breach. In a letter dated January 10, 2022, the Administrator stated that in order to minimize this risk, he decided to implement a corrective action plan, under which "(...) 1. The security of the network and client computers was enhanced by installing a more advanced security-focused antivirus system (...) with disk encryption and anti-phishing protection. 2. In accordance with the security policy, the ability to connect external devices [USB drives, CDs, external disks] to workstations was restricted. 3. The rules and policies on F. were updated to minimize the risk of a similar situation occurring again. 4. Reinstallation of database servers and reallocation of resources. 5. The purchase of a new, more advanced firewall was planned (...). 6. Modification and upgrade of system Y - a tool used for (...). Security nodes of the computer network were analyzed for unwanted resources [programs, applications]. 7. The purchase of a tool for (...). 8. An audit of the breach was commissioned to an external company. Currently, work is underway on the technical analysis of system logs (...)"

In a letter dated March 3, 2022, the Administrator stated that "on (...) February 2022, an agreement was signed for , the subject of which is a security system that currently meets the highest requirements (...)." Attached to the aforementioned letter, the Administrator provided a copy of the contract mentioned above.

IX. In response to the request of the President of the UODO to indicate the role of G. as an entity participating in the processing of the data involved in the breach, in a letter dated February 16, 2022, the Administrator explained that "(...) G. had its own database, which it processed independently, although it was located on the same server as the database of the Nowiny Commune Office. The manager of G. in Nowiny independently reported the incident. Regarding the infection and subsequent unauthorized disclosure of G.'s database, a separate explanatory procedure is being conducted by your Office (...)"

X. The Administrator provided explanations regarding the server software. In response to the President of the UODO's request to specify the installed server software prior to the occurrence of the personal data breach, the Mayor explained in a letter dated February 16, 2022, that "(...) currently we are unable to clearly identify the server software prior to the date of the incident, due to the fact that we cannot establish a connection with it. There is reasonable suspicion that it was password-protected by (...), who did not provide the login and password (...)" In this regard, the Administrator also provided explanations in a letter dated March 3, 2022. The supervisory authority inquired how the risk analysis was conducted, given that the administrator does not have information on what software was installed on the encrypted server. In the aforementioned letter, the Administrator stated that "(...) I clarify that at the time of drafting the response Reference: (...) dated February 16, 2022, we were unable to identify all programs installed on the infected server. However, we were certain that the attack concerned programs H. and B. - these two programs were disabled as a result of the attack. In the aforementioned response, we did not mention this software, as it was, from our point of view, an obvious circumstance - a misunderstanding. The indication that <(...) we are unable to clearly identify the server software prior to the date of the incident, due to the fact that we cannot establish a connection with it> obviously referred to any other software besides the aforementioned. The risk analysis was conducted taking into account the circumstances of what type of data is processed within programs H. and B. and based on data from two IT audits conducted in 2020 and 2021 (...)" To obtain further clarifications in this regard, the President of the UODO again requested to specify exactly what software was installed on the server prior to the occurrence of the breach. In a letter

dated June 17, 2022, the Administrator indicated that "(...) during the personal data breach, version (...) of system Z. was used (...)".

XI. The supervisory authority requested the Mayor to indicate the role of the data protection officer in actions aimed at ensuring the security of personal data involved in the personal data breach. In this regard, the Administrator explained in a letter dated February 16, 2022, that "(...) The Data Protection Officer was involved in actions aimed at ensuring the security of personal data involved in the breach. He carried out his tasks as specified in Article 39 of the GDPR, and the Administrator had no objections to the cooperation with the Officer. In the context of the incident, at the initial stage (...) informed the Data Protection Officer that in the described incident there was no unauthorized access to personal data through the infection of the computer, nor was there unauthorized insight into the stored personal data, and that the lost personal data were not irretrievably lost. However, starting from (...) December 2021, the Officer actively participated in the actions taken. He was the initiator of the meeting held on (...) December 2021. The content of the communication and notifications directed to the affected individuals was developed with his participation. He also prepared (...)".

Furthermore, in a letter dated March 3, 2023, the Mayor stated that "(...) Monitoring compliance with the provisions of Regulation 2016/679 by the data protection officer was conducted during his monthly meetings.

\*\*Visits to the Municipal Office. It should be noted that the current Data Protection Officer (DPO) has been supervising our facility since October 2021. Until (...) October 2021, the supervision over compliance with data protection regulations was carried out by V., however, due to improper performance of duties, the contract was terminated by the Municipality by means of a declaration of termination of the agreement, with the imposition of contractual penalties for improper performance of its provisions. The documentation of activities is maintained through the preparation of reports from DPO visits [attached] and keeping official records in the database of company C. (...)\*\*

\*\*XII. The Administrator explained in a letter dated March 3, 2022, that "(...) there is no separate, dedicated register of devices and information systems maintained at the Office. The obligation in this regard is fulfilled within the framework of the accounting records kept and the annual inventories conducted. The information generated from the F. system is current and complete at the moment. In the case of so-called low-value fixed assets, i.e., those that due to their low value are charged to the costs of material consumption at the time they are put into use, the records are kept manually within the inventory books. Attached is a printout from the F. software as well as a photocopy of the inventory books regarding devices and information systems. One of the recommendations from the conducted in 2021 [chapter p. 8] is to introduce a separate, additional record for managing equipment and software in the office. This recommendation will be implemented by the end of 2022 (...)." In this regard, the Administrator submitted additional explanations in a letter dated July 13, 2023, in which he indicated that "(...) the Municipal Office purchased and implemented on (...) August 2022 dedicated software for managing equipment and software records (...).\*\*

\*\*Due to the limited technical capabilities of this software, a decision was made to change the system. The Office ultimately implemented and is using the system (...) which meets the requirements and expectations regarding the management of both equipment and software (...)." Along with the explanations, the Administrator attached: - invoices for the purchase of the aforementioned programs, - implementation documentation for the aforementioned system, - a sample printout of the inventory status of computers recorded in the system.\*\*

\*\*XIII. In response to the request of the President of the Personal Data Protection Office (UODO) for information on how the Administrator mitigated the risk of personal data breaches concerning the possibility of encrypting servers used for processing personal data at the Municipal Office of Nowiny, the Mayor explained in a letter dated June 17, 2022, that "(...) the risk of personal data breaches concerning the possibility of encrypting servers used for processing personal data at the Municipal Office of Nowiny was monitored using possible audits and analyses, such as: a) "Analysis (...)" of the Municipal Office of Nowiny, prepared in May 2021 by R.S. conducting business under the name R. based in K. (...) b) The Municipal Office of Nowiny was subject to Order No. (...) dated (...) August 2018

regarding the introduction of Policy (...), containing procedures and principles of action in the event of a personal data breach, which the IT services were obliged to follow (...) c) An annual audit is conducted at the Municipal Office of Nowiny regarding the state of information processing security. Audits are documented with appropriate protocols containing an assessment of the existing state and recommendations formulated as a result of this assessment. The conduct of these audits is entrusted each time to professional entities authorized to carry them out (...).”\*\*

\*\*The supervisory authority assessed the evidence material in terms of examining its credibility and evidential value. The President of UODO considered the evidence submitted by the Administrator to be credible. This is supported by the fact that the Mayor's explanations are logical, coherent, and correlate with the entirety of the evidence material and are confirmed by a series of documents provided by the Administrator. In this factual state, after reviewing all the evidence collected in the case, the President of the Personal Data Protection Office considered the following: According to Article 34 of the Act of May 10, 2018 on Personal Data Protection (Journal of Laws of 2019, item 1781) - hereinafter referred to as the Act of May 10, 2018, the President of UODO is the competent authority in matters of data protection and the supervisory authority within the meaning of Regulation 2016/679. Pursuant to Article 57(1)(a) and (h) of Regulation 2016/679, without prejudice to other tasks specified under this regulation, each supervisory authority in its territory monitors and enforces the application of this regulation and conducts proceedings regarding breaches of this regulation, including based on information received from another supervisory authority or another public authority. Article 5 of Regulation 2016/679 formulates principles regarding the processing of personal data that must be respected by all administrators, i.e., entities that independently or jointly with others determine the purposes and means of processing personal data. According to Article 5(1)(f) of Regulation 2016/679, personal data must be processed in a manner that ensures appropriate security of personal data, including protection against unauthorized or unlawful processing and against accidental loss, destruction, or damage, using appropriate technical or organizational measures (“confidentiality and integrity”). Furthermore, according to Article 5(2) of Regulation 2016/679, the administrator is responsible for compliance with the provisions of paragraph 1 and must be able to demonstrate compliance.\*\*

("accountability"). The specification of the confidentiality principle referred to in Article 5(1)(f) of Regulation 2016/679 is provided by further provisions of this legal act. According to Article 24(1) of Regulation 2016/679, taking into account the nature, scope, context, and purposes of processing as well as the risk of infringement of the rights or freedoms of natural persons with varying probabilities and severity, the controller implements appropriate technical and organizational measures to ensure that processing is performed in accordance with this regulation and to be able to demonstrate it. These measures are reviewed and updated as necessary.

Pursuant to Article 25(1) of Regulation 2016/679, taking into account the state of technical knowledge, the cost of implementation, and the nature, scope, context, and purposes of processing as well as the risk of infringement of the rights or freedoms of natural persons with varying probabilities of occurrence and severity arising from processing, the controller—both when determining the means of processing and during the processing itself—implements appropriate technical and organizational measures, such as pseudonymization, designed to effectively implement data protection principles, such as data minimization, and to provide the processing with necessary safeguards to meet the requirements of this regulation and protect the rights of data subjects.

From the content of Article 32(1) of Regulation 2016/679, it follows that the controller is obliged to apply technical and organizational measures corresponding to the risk of infringement of the rights and freedoms of natural persons with varying probabilities of occurrence and severity of the threat. The provision specifies that when deciding on technical and organizational measures, one must take into account the state of technical knowledge, the cost of implementation, the nature, scope, context, and purposes of processing, and the risk of infringement of the rights or freedoms of natural persons with varying probabilities of occurrence and severity. The cited provision indicates that determining appropriate technical and organizational measures is a two-step process.

Firstly, it is essential to determine the level of risk associated with the processing of personal data, considering the criteria indicated in Article 32(1) of Regulation 2016/679, and then to establish what technical and organizational measures will be appropriate to ensure a level of security corresponding to that risk. These determinations, where appropriate, should include measures such as pseudonymization and encryption of personal data, the ability to ensure the ongoing confidentiality, integrity, availability, and resilience of processing systems and services, the ability to restore the availability of personal data and access to it in a timely manner in the event of a physical or technical incident, and regular testing, measuring, and evaluating the effectiveness of technical and organizational measures to ensure processing security.

According to Article 32(2) of Regulation 2016/679, when assessing whether the level of security is appropriate, the controller takes into account, in particular, the risks associated with processing, especially those arising from accidental or unlawful destruction, loss, alteration, unauthorized disclosure of, or unauthorized access to personal data transmitted, stored, or otherwise processed.

As indicated in Article 24(1) of Regulation 2016/679, the nature, scope, context, and purposes of processing as well as the risk of infringement of the rights or freedoms of natural persons with varying probabilities and severity are factors that the controller is obliged to consider in the process of building a data protection system, also particularly from the perspective of other obligations indicated in Article 25(1), Article 32(1), or Article 32(2) of Regulation 2016/679. The indicated provisions specify the confidentiality principle defined in Article 5(1)(f) of Regulation 2016/679, and adherence to this principle is necessary for the proper implementation of the accountability principle resulting from Article 5(2) of Regulation 2016/679.

Taking into account, in particular, the scope of personal data processed by the Mayor, in order to properly fulfill the obligations imposed by the aforementioned provisions of Regulation 2016/679, the Controller was obliged to take actions ensuring an adequate level of data protection by implementing appropriate technical and organizational measures, as well as actions aimed at optimal configuration of the information systems used through regular testing, measuring, and evaluating the effectiveness of technical and organizational measures to ensure the security of data processing in the form of security tests concerning the IT infrastructure and applications. The nature and type of these actions should result from the conducted risk analysis, in which vulnerabilities related to the resources used should be identified along with the resulting threats, and then appropriate security measures should be determined. Incorrect estimation of the level of risk prevents the application of appropriate security measures for a given resource and increases the likelihood of its occurrence.

The gathered evidence indicates that the Mayor conducted a risk analysis both before and after the occurrence of the personal data breach. In the further part of this decision, those risks that the Controller anticipated and which are related to the subject breach will be indicated.

As indicated by the risk analysis conducted in May 2021 (i.e., before the personal data breach), the Controller anticipated risks of personal data breaches related to a ransomware attack. A detailed description of the risks significant from the perspective of this case can be found in the factual justification (see point IV of the factual justification). The key fact in this case is that the Controller anticipated a high risk of occurrence of events.

having a direct (or relatively indirect) connection to the subject violation of personal data protection. For example, the Administrator anticipated the risk associated with the installation and use of malicious software or the susceptibility of users to the influence of social engineering methods in order to obtain information or introduce malicious code. Furthermore, the risk analysis included a detailed (developed according to the template adopted by the Administrator) scale of risk levels precisely indicating how the Administrator would handle this risk in relation to specific threats. The submitted document stated that "(...) risks for which the final risk level is lower than or equal to 20% of the maximum level  $R_h < 9.6$  are subject to automatic acceptance but remain under the supervision of the risk owner for further monitoring. Risks for which the level falls within the range of  $9.6 < R_k < 38.4$  are subject to acceptance according to the principles established in this document, or they undergo re-analysis. Risks for which the risk level is greater than 80% of the maximum level  $R_k < 38.4$  are presented for acceptance by



the ADO, and a risk management process may be conducted to minimize it (...).

Moreover, the risk analysis included a recommendation to implement remedial measures, particularly in those areas where the risk ultimately materialized. It was recommended, among other things: "(...)"

From the above, it follows that the Mayor was aware of the possibility of loss of confidentiality of data and loss of access to processed personal data as a result of a ransomware attack. It should be emphasized that the implementation of the measures provided by the Administrator would have eliminated or significantly reduced the risk of security incidents, including breaches of personal data protection. As evidenced by the collected evidence, the breach of personal data protection occurred as a result of one of the Administrator's employees opening an email attachment that was infected with ransomware. The Administrator, as indicated, did not install an appropriate antivirus system and did not activate the firewall service. A detailed description of the vulnerabilities and their impact on the materialization of the risk used to conduct the attack is found in the "Report (...)" (see point VII of the factual justification) and in the further part of the decision. Due to the breach of the Mayor's IT system security, data, including personal data, were encrypted, resulting in the loss of availability to the Administrator's databases, as well as the loss of confidentiality of personal data, since, as indicated by the collected evidence (see point II of the factual justification of this decision), the data was disclosed (...).

At the outset, it should be noted that, in general terms, the cause of the breach of personal data protection was the application of inadequate security measures for the personal data processing process. Moving on to the causes of the discussed incident, it should first be pointed out that the Mayor, despite having identified risks related to the lack of updates to the system software in the risk analysis, underestimated the probability of its materialization. From the submitted explanations, it follows that the Administrator used Z. as the operating system installed on the server at the time of the breach of personal data protection (see point X of the factual justification of this decision). It is also worth emphasizing that the Administrator was aware, firstly, of the use of outdated server software, and secondly, of the recommendations issued in this regard (see Risk Analysis and Audit Report, discussed in detail in points IV and VII of the factual justification).

In light of the above, it should be emphasized that one of the significant elements affecting the security of personal data is ensuring that the software used for processing personal data is supported by its manufacturer. This ensures that the Administrator will have access to all updates issued by the manufacturer, including security updates and patches affecting security. In the discussed case, the Administrator used a system that lost manufacturer support on the day of (...) According to the information provided on the manufacturer's website, since (...) there have been no additional local free security updates, non-security-related updates, free technical support options, or online technical content updates.

In this context, it should be noted that using IT systems for processing personal data after the end of technical support by their manufacturer significantly lowers their security level. The lack of built-in and updated security increases, in particular, the risk of infection by malicious software and attacks due to the emergence of new vulnerabilities. These systems become more susceptible to cyberattacks, including ransomware attacks that block access to data and demand a ransom for its recovery.

In summary, it should be noted that the Administrator identified the risk associated with using outdated software before the breach of personal data protection, but despite this, processed data using software that had lost manufacturer support and, contrary to the conclusions from the risk analysis and conducted audits, did not take any action to replace this software with one that had such support.

Another issue that requires emphasis is the fact that

risk analysis conducted by the Administrator prior to the occurrence of a personal data breach identified threats arising from the lack of installed antivirus software or the absence of updates for such software. In this regard, the risk analysis also included appropriate recommendations aimed at mitigating the discussed risk (p. 19 "Threat and Risk Analysis in Personal Data Processing": "[...] it is recommended to install antivirus software on all servers. It should be ensured that the virus definition

database is kept up to date, preferably automatically. The system firewall should be activated and additionally configured if necessary [...]"). As indicated by the submitted explanations and the documents provided, the subject personal data breach was caused by a ransomware attack, which occurred, among other reasons, due to the exploitation of a vulnerability present in the IT system, which also included the lack of antivirus software installation (cf. "Report (...)", referred to in point VII of the factual justification). Therefore – just as in the case of the lack of updates to the system software – the Mayor neglected the possibility of the materialization of the risk associated with the absence of antivirus software and, despite specifying recommendations in the risk analysis in this regard, did not adhere to the procedures he himself defined.

The post-breach report also indicates other gross negligence by the Administrator in ensuring appropriate security measures for the processed personal data. As indicated in this report, "the server (...) had the (...) disabled, which had the status DISABLED. The infected (...) with IP address (...) was allowed all outgoing and incoming network traffic, which could have allowed an unauthorized person to take over the server, which, having access to the server (...), carried out a ransomware attack. No security measures were disclosed on the device, as noted in the Security Audit." The above clearly confirms that the Mayor failed to fulfill his obligations regarding the proper protection of personal data imposed on him as an administrator by the provisions of Regulation 2016/679.

As evidenced by the collected evidence, attempts to recover access to the encrypted data were unsuccessful, as stated in the post-breach report submitted by the Administrator (cf. point VII of the factual justification). From the explanations provided, it follows that the Mayor did not conduct an effective personal data protection policy in the area of performing backups of processed personal data (despite the fact that the risk analysis identified threats to data availability related to performing backups). Backups, as indicated in the explanations provided, were indeed performed, but ultimately, after the breach of data availability, the Administrator was forced to restore personal data to the state as of September 2019. The reason for this, as admitted by the Administrator himself, was the failure to adhere to backup creation principles. As the Administrator indicated, "(...) incremental backup from September 2019 was performed daily, but it was stored on the infected server, and as a result, it was encrypted along with the other data (...)". Furthermore, the Administrator did not conduct tests for data recovery from backups. A detailed description of the Administrator's explanations in this regard was included in point V of the factual justification.

Taking into account the above, i.e., the loss of access to data stored in the backup copy kept on the server that was attacked and encrypted, the Mayor was forced to restore data also based on paper documentation. Consequently, the Administrator was unable to efficiently and in a relatively short time restore the encrypted data. Although the Mayor could carry out ongoing tasks related to data processing, this does not change the fact that the principle of data availability in the area of personal data processing for archival purposes was violated (cf. point V of the factual justification).

In this context, it should be noted that the backup creation principles applicable to the Administrator (prior to the occurrence of the personal data breach) and the practice of performing this backup did not ensure the fulfillment of the obligations arising from Article 32(1)(b) and (c) of Regulation 2016/679, i.e., the ability to ensure the ongoing availability of processing systems and services and the ability to quickly restore the availability of personal data and access to it in the event of a physical or technical incident. Key in this case is again that the Administrator did not comply with his own procedures, which, as indicated by the explanations provided, were changed following a security audit conducted by an external entity in 2021.

As evidenced by the collected evidence, the Administrator conducted training covering issues related to personal data protection (cf. point VI of the factual justification), however, the cybersecurity training for employees was conducted shortly before the occurrence of the personal data breach (on (...) October 2021). As the Administrator himself admitted, the lack of previously conducted training was one of the reasons for terminating the contract for the function of Data Protection Officer and supervision over compliance with data protection regulations with the service provider V as of (...) October 2021. Training was also conducted on (...) December 2021, i.e., after the occurrence of the

personal data breach. In light of the above findings, it should be emphasized that properly conducted training allows trained individuals to adequately understand the principles of personal data processing defined by the Administrator, and consequently contributes to limiting risks of violations occurring in this area.

Conducting training on personal data protection, in order to be considered an adequate security measure, must be carried out periodically, which will ensure constant reminders and, consequently, the reinforcement of the principles of processing personal data covered by the training. Furthermore, all individuals authorized to process personal data must participate in such training, and the training program must cover all issues related to the processing of personal data within the established topic of the training. The omission of any of these elements will result in the training not fulfilling its role, as some individuals will not be trained at all, or the participants will not receive complete knowledge in this area. The consequence of the above may be a violation of personal data protection. It should be emphasized at this point that in this case, one of the reasons for the occurrence of the ransomware attack was the opening of an attachment from a work email by one of the employees (the attachment turned out to be a virus-infected executable file of ransomware named B.). It is therefore justified to state that negligence in conducting training influenced the occurrence of the aforementioned violation, as properly conducted training, which addresses the topic of personal data protection, should indicate the risks associated with the use of social engineering tools such as, for example, sending infected virus emails. The lack of training conducted in the manner described above means that this security measure does not effectively reduce the risk of personal data protection violations, which undoubtedly contributes to weakening the level of personal data protection and determines the necessity of recognizing a violation of the provisions of Regulation 2016/679 relating to the obligations of the data controller regarding data security. It must also be remembered that training cannot replace technical solutions. It should therefore be emphasized that the training conducted by the Administrator on (...) October 2021 was ineffective, as less than a month had passed from the date of this training to the date of the occurrence of the personal data protection violation. Moreover, the Administrator did not demonstrate that any other training was conducted prior to the occurrence of the personal data protection violation. Therefore, in this regard, one cannot perceive cyclicity in the actions of the Mayor. In light of the above, the training conducted by the Mayor before the occurrence of the personal data protection violation cannot be considered an adequate security measure.

It should be noted that Regulation 2016/679 introduced an approach in which risk management constitutes the foundation of actions related to personal data protection. Risk management is a continuous process that requires the data controller not only to ensure compliance with the provisions of Regulation 2016/679 through a one-time implementation of organizational and technical security measures but also to ensure the continuity of monitoring the level of threats and to ensure accountability regarding the level and adequacy of the implemented safeguards. Therefore, it becomes necessary to be able to prove before the supervisory authority that the solutions implemented to ensure the security of personal data are adequate to the level of risk, as well as take into account the nature of the organization and the mechanisms used for processing personal data. The Administrator must therefore conduct a detailed analysis of the data processing processes and assess the risk, and then apply such measures and procedures that will be adequate to the estimated risk. The consequence of such an approach is the necessity of independently selecting safeguards based on a threat analysis. Specific security measures and procedures are not indicated for the Administrators. As indicated above, the gathered evidence shows that the Administrator conducted a risk analysis that correctly identified threats to security in the process of personal data processing; however, the technical and organizational measures implemented by the Mayor did not provide an adequate level of security for the data processed through information systems. This resulted in the failure of security mechanisms to function. In light of the above, it must be stated that the Mayor did not implement technical and organizational measures during the processing of personal data to ensure that this processing was carried out in accordance with Regulation 2016/679 and to provide the necessary safeguards for the processing, which he was obliged to do in accordance with Article 24(1) and Article 25(1) of Regulation 2016/679, nor did he apply technical and organizational measures ensuring a level of security appropriate to the risk of violation of the rights or freedoms of natural persons by ensuring

the ability to continuously ensure the confidentiality, integrity, availability, and resilience of processing systems and services, as required by Article 32(1)(b) of Regulation 2016/679, the ability to quickly restore the availability of personal data and access to it in the event of a physical or technical incident, as stated in Article 32(1)(c) of Regulation 2016/679, and the failure to assess whether the level of security is appropriate, taking into account the risks associated with the processing of personal data, the obligation to conduct which arises from Article 32(2) of Regulation 2016/679, and consequently also the violation of the principle of confidentiality expressed in Article 5(1)(f) of Regulation 2016/679, which the aforementioned provisions specify. As the Provincial Administrative Court in Warsaw stated in its judgment of August 26, 2020, sygn. II SA/Wa 2826/19 "(...) actions of a technical and organizational nature fall within the responsibility of the personal data controller, but they cannot be selected in a completely free and voluntary manner, without considering the degree of risk and the nature of the protected personal data (...)." The consequence of the Administrator's violation of the confidentiality principle is a breach of the accountability principle referred to in Article 5(2) of Regulation 2016/679.

It is significant in this case that the Mayor took actions aimed at identifying weaknesses in the solutions adopted by him in the area of personal data protection. An example of such actions are the security audits conducted by an external entity in 2020 and 2021, which were discussed in detail in point VII of the factual justification (it is unnecessary to repeat excerpts from the aforementioned reports here). According to the submitted documents, the purpose of the audit was "(...) to present the state of information security observed by the auditors in the unit and to indicate any vulnerabilities affecting the processed data (...)." The audit reports contained a description of the factual state of the existing infrastructure intended to ensure security in the data processing process and recommendations whose implementation was supposed to increase or guarantee that security.

In the opinion of the President of the UODO, conducting such audits can be considered an element of regular testing, measuring, and evaluating the effectiveness of technical and organizational measures aimed at ensuring the security of processing (Article 32(1)(d) of Regulation 2016/679). At the same time, it should be noted that the overall picture emerging from the aforementioned reports indicates significant neglect by the Administrator in the area of security in systems used for processing personal data. Ultimately, it is this series of neglects (known to the Administrator) that significantly contributed to the materialization of risks, of which the Administrator was also aware (as indicated by the submitted risk analysis).

It should be emphasized that the recommendations contained in the reports were not implemented. For example, despite the recommendation to install antivirus software, none of the servers used for processing personal data, i.e. (...) had antivirus protection installed. Considering the date of entry into force of the provisions of Regulation 2016/679 and the Administrator's awareness of gaps in the security system used for processing personal data, it is crucial to note that the Administrator did not take (and consequently is unable to demonstrate to the supervisory authority – which he is obliged to do in connection with the accountability principle specified in Article 5(2) of Regulation 2016/679) effective actions aimed at adapting the organizational and technical solutions used in the personal data processing process to ensure an adequate level of security that would correspond to the risk of infringement of the rights or freedoms of natural persons.

It should also be emphasized that the level of violation of the accountability principle is very significant, as evidenced by the fact that the Administrator does not even possess knowledge regarding the details of the password that was supposed to secure the stolen database. Effective implementation of a security measure, such as encrypting the stolen database, would have limited the possibility of breaching data confidentiality. At the same time, it should be noted that the Administrator attempts to shift the responsibility for the non-implementation of the procedures he established onto an employee (employed in the position of (...)), who allegedly failed to fulfill his duties (cf. III point of the factual justification). The Administrator explained, among other things, that "(...) the audit for 2020 revealed a number of deficiencies that ultimately were not addressed despite the employee's assurances, as indicated by the audit data for 2021.

The behavior of (...) also raised concerns during her ongoing work performance. Particular doubts concerned the lack of any reaction to the verbally issued, and subsequently written, official orders to note down and deposit all passwords necessary for full administration of the network. These passwords were not made available contrary to the order to an employee hired on (...) April 2021 (...). Only the occurrence of the incident enabled the almost forced enforcement of the order (...).” In this context, it is particularly concerning that the Administrator delayed for so long (considering the date he received the audit reports) in enforcing the fulfillment of his employee's obligations related to ensuring the security of the IT system used for the processing of personal data. In fact, it was only the occurrence of a personal data breach that seemingly compelled the Administrator to take some actions in this area. The above constitutes evidence of gross negligence and disregard for the Administrator's tasks (including those related to supervising the employee responsible for ensuring the security of the unit's IT environment), which indicates an improper approach by the Administrator to the obligations arising from ensuring security in the personal data processing process.

In the area of oversight over the security of implemented technical and organizational solutions, the significant role of the data protection officer should be highlighted. According to Recital 77 of Regulation 2016/679, guidance on how to implement appropriate measures and demonstrate compliance with the law by the controller or processor of data – particularly regarding identifying risks associated with processing, assessing them in terms of source, nature, probability, and severity, as well as best practices to minimize that risk – can be provided in particular...

the case of an enterprise - up to 4% of its total annual worldwide turnover from the previous financial year, with the higher amount applicable.

In this case, the administrative fine imposed on the Mayor was for the violation of Article 25(1) and Article 32(1) and (2) of Regulation 2016/679 based on the aforementioned Article 83(4)(a) of Regulation 2016/679, while for the violation of Article 5(1)(f) and Article 5(2) of Regulation 2016/679 - based on Article 83(5)(a) of that regulation. At the same time, the fine imposed on the Mayor for the violation of all the above provisions - in accordance with Article 83(3) of Regulation 2016/679 - does not exceed the amount of the fine for the most serious violation identified in this case, namely the violation of Article 5(1)(f) and Article 5(2) of Regulation 2016/679, which in accordance with Article 83(5)(a) of Regulation 2016/679 is subject to an administrative fine of up to 20,000,000 EUR, and in the case of an enterprise - up to 4% of its total annual worldwide turnover from the previous financial year, with the higher amount applicable.

in the case of an enterprise - up to 4% of its total annual worldwide turnover from the previous financial year.

In deciding to impose an administrative monetary penalty, the President of the UODO - in accordance with the provisions of Article 83(2)(a) - (k) of Regulation 2016/679 - took into account the following circumstances of the case, which necessitate the application of this type of sanction in the present case and which adversely affect the amount of the imposed administrative monetary penalty:

1. The nature, gravity, and duration of the infringement, taking into account the nature, scope, or purpose of the processing in question, the number of affected individuals whose data are involved, and the extent of the damage suffered by them (Article 83(2)(a) of Regulation 2016/679). The infringement of personal data protection regulations established in this case, resulting in the loss of availability and confidentiality of data processed by the Mayor, which occurred as a result of a ransomware attack, is of significant weight and serious nature, as it posed a high risk of negative legal consequences for an indeterminate, potentially large number of individuals (the Mayor indicated that the data breach concerns approximately 1,000 individuals).

In the opinion of the President of the UODO, the organizational and technical measures adopted by the Administrator proved to be insufficient, and to his detriment, the fact that the Mayor was aware of the need to implement appropriate changes in this area but ignored the recommendations contained in the audit reports weighs against him. Ultimately, due to the Administrator's passivity, the risk of exploiting the weaknesses of the organizational and technical measures intended to secure the personal data processing materialized. The Mayor's failure to fulfill the obligations to apply measures

to secure the processed data against unauthorized access not only entails a potential but also a real possibility of these data being used by third parties without the knowledge and against the will of the individuals concerned, in violation of the provisions of Regulation 2016/679, e.g., for the purpose of establishing legal relations or incurring obligations on behalf of the individuals whose data were obtained.

It should be emphasized that the Mayor, as an executive body of the local government (municipality), is a public trust entity, which requires both knowledge of the regulations and their proper application, and thus high standards in terms of the security of processed data.

At the same time, it should be noted that the Administrator recovered all encrypted data only several months after their loss. It should also be emphasized that backup copies of the databases were made until (...) September 2019, while the deadline declared by the Administrator for restoring personal data from the paper version was set for the end of the third quarter of 2022. From the above, it follows that the state of violation of the provisions of Regulation 2016/679 persisted for at least from (...) September 2019 to the third quarter of 2022, which indicates the serious nature, significant weight, and several years of duration of the established violation of the provisions of Regulation 2016/679.

In this case, there is no evidence that individuals whose data could have been accessed by unauthorized persons suffered material damage. Nevertheless, the mere breach of confidentiality of their data (in connection with the disclosure of personal data (...)) constitutes non-material damage (harm) for them; individuals whose data were unlawfully obtained may at least feel fear of losing control over their personal data, identity theft or identity fraud, discrimination, or finally financial loss. As indicated by the District Court in Warsaw in the judgment of August 6, 2020, case file XXV C 2596/19, fear, and thus loss of security, constitutes a real non-material damage associated with the obligation to remedy it.

Furthermore, the Mayor lost full access to the personal data he processed in connection with the performance of the tasks entrusted to him. Therefore, it should be assumed that there was a risk of being unable to handle the matters of specific individuals (whose data were breached) within the time limits provided for in separate regulations, i.e., the Mayor, instead of performing his tasks within statutory deadlines, using the processed personal data (to which he lost access as a result of the breach), had to first regain access to them.

2. The intentional nature of the infringement (Article 83(2)(b) of Regulation 2016/679). According to the Guidelines of the Article 29 Working Party on the application and determination of administrative monetary penalties for the purposes of Regulation No. 2016/679 WP253 (adopted on October 3, 2017, approved by EROD on May 25, 2018), intent "includes both knowledge and deliberate action, in relation to the characteristics of the prohibited act." The Administrator was aware that in the case of allowing the processing of personal data in IT systems, he should process personal data in such a way as to ensure their appropriate security, including protection against potential malware attacks, and thus in such a way as to ensure compliance with the principle of "integrity and confidentiality" expressed in Article 5(1)(f) of Regulation 2016/679. The Mayor, due to the scope of the activities of the Office he manages, was aware of the possibility of a breach of personal data protection as a result of a ransomware attack, as evidenced by at least the risk analysis conducted and the reports from the security audits carried out.

It should be emphasized that the significant impact on the occurrence of the infringement in question was the gross negligence of the local government authority. The Mayor despite being aware of the threat to security in the process of processing personal data related to the likelihood of a ransomware attack, took actions regarding the protection of personal data in a negligent manner. Evidence of this negligence is the lack of full implementation of the recommendations contained in the audit reports. In particular, it should be noted that the Mayor did not implement the recommendations regarding the installation of antivirus software. Furthermore, it should be pointed out that the Administrator was aware of the necessity to develop and implement a backup procedure. According to the recommendation contained in the report following the audit conducted on (...)

November 2021, backups should be stored outside the utilized IT infrastructure. The development of appropriate procedures regarding the execution of backups, and subsequently their implementation, would significantly limit the effects of a data availability breach. In the case discussed, the Administrator, despite having knowledge, did not introduce effective solutions in this regard.

It should be added that the post-breach audit indicates that the individuals who conducted the hacking attack penetrated the Administrator's resources, discovered weaknesses in the organization, and subsequently made further manipulations in the Administrator's IT system (cf. point VII of the factual justification). It can be stated with a high degree of probability that the implementation of the recommendations by the Mayor (widely described in point VII of the factual justification) would have eliminated or significantly reduced the possibility and consequences of a breach of personal data protection. Thus, the Mayor intentionally violated the provisions on the protection of personal data - Article 5(1)(f) of Regulation 2016/679 in conjunction with Article 24(1), 25(1), 32(1) and (2) of Regulation 2016/679, and consequently also Article 5(2) of Regulation 2016/679.

Considering the findings in the matter subject to the resolution of this decision, it should be stated that the Administrator committed negligence resulting in a breach of personal data protection, which occurred as a result of, among other things, the intentional actions of the local government authority. Thus, this constitutes a significant circumstance affecting the severity of the administrative monetary penalty.

3. Categories of personal data affected by the breach (Article 83(2)(g) of Regulation 2016/679). The personal data contained in the Mayor's resources, to which he lost access as a result of the ransomware attack and which were published (...), did not belong to special categories of personal data referred to in Article 9 of Regulation 2016/679, nor to data specified in Article 10 of Regulation 2016/679; however, their scope, i.e., surnames and first names, parents' names, date of birth, bank account number, residential or stay address, PESEL identification number, mother's maiden name, series and number of the identity card, and phone number, is associated with a high risk of infringement of the rights or freedoms of the individuals affected by the breach. It should be emphasized that the fact that the breach of personal data protection involved such categories of data as the PESEL identification number along with the first and last name, which unequivocally identify an individual, can realistically and negatively affect the protection of the rights or freedoms of that person. It should be noted that the PESEL identification number, which is an eleven-digit numerical symbol that unequivocally identifies an individual, containing, among other things, the date of birth and gender designation, and thus closely related to the private sphere of the individual and also subject to, as a national identification number, exceptional protection under Article 87 of Regulation 2016/679, is data of a special nature and requires such special protection.

In determining the amount of the administrative monetary penalty, the President of the UODO considered as a mitigating circumstance, which influenced the reduction of the imposed penalty, the good cooperation of the Administrator with the supervisory authority undertaken and conducted in order to eliminate the breach and mitigate its potential negative effects [Article 83(2)(f) of Regulation 2016/679]. It should be pointed out that beyond properly fulfilling the procedural obligations imposed on the Mayor during the administrative proceedings, which concluded with the issuance of this decision, the Mayor fully implemented the recommendations of the President of the UODO regarding the supplementation of the notification to the individuals whose data are concerned about the breach that occurred. It should be noted that the Mayor's actions in this regard allowed for the mitigation of potential negative effects of the breach as the individuals whose data were breached received information regarding, among other things, a description of the possible consequences of the breach of their personal data protection. Furthermore, the Administrator undertook a number of actions aimed at eliminating the breach, such as actions aimed at recovering encrypted data, or introducing changes in the area of organizational and technical measures ensuring security in the process of processing personal data. In the opinion of the President of the UODO, the execution of the aforementioned actions should be considered a mitigating circumstance affecting the reduction of the imposed penalty.

Other circumstances, as indicated below, referred to in Article 83(2) of Regulation 2016/679, after

assessing their impact on the breach established in this case, were considered by the President of the UODO to be neutral in his assessment, meaning they had neither an aggravating nor a mitigating effect on the amount of the imposed administrative monetary penalty.

1. Actions taken to minimize the damage suffered by the individuals whose data are concerned (Article 83(2)(c) of Regulation 2016/679). The actions of the Administrator were limited in this regard, exclusively for notifying individuals of the breach. However, this notification is merely a fulfillment of the legal obligation arising from Article 34(3)(c) of Regulation 2016/679, as stated in the Guidelines adopted on October 3, 2017, by the Article 29 Working Party on the application and determination of administrative fines for the purposes of Regulation No. 2016/679, hereinafter referred to as WP253 Guidelines (with regard to the criterion of “the manner in which the supervisory authority became aware of the breach”) “[t]he mere fulfillment [...] of the obligation by the controller cannot be interpreted as a mitigating factor.”

2. The degree of responsibility of the controller, taking into account the technical and organizational measures implemented by it under Articles 25 and 32 (Article 83(2)(d) of Regulation 2016/679). The WP253 Guidelines indicate that - when considering this criterion - “the supervisory authority must answer the question of to what extent the controller, considering the nature, purposes, or scope of processing and in light of the obligations imposed on it by the regulation.” The President of the UODO stated in this case that the Mayor violated the provisions of Articles 25(1) and 32(1) and (2) of Regulation 2016/679. In his opinion, the controller bears a high degree of responsibility for failing to implement appropriate technical and organizational measures that would have prevented the breach of personal data protection. It is evident that in the context of the nature, purpose, and scope of processing personal data, the Controller did not “do everything that could be expected of him”; thus, he did not fulfill the obligations imposed on him by Articles 25 and 32 of Regulation 2016/679. In this case, this circumstance constitutes the essence of the breach of the provisions of Regulation 2016/679; it is not merely a factor influencing - either mitigating or aggravating - its assessment. For this reason, the lack of appropriate technical and organizational measures referred to in Articles 25 and 32 of Regulation 2016/679 cannot be considered by the President of the UODO in this case as a circumstance that could additionally influence a stricter assessment of the breach and the amount of the administrative fine imposed on the Mayor.

3. Any relevant prior breaches by the controller or processor (Article 83(2)(e) of Regulation 2016/679). The President of the UODO did not find any prior breaches of personal data protection regulations committed by the Controller, which means there are no grounds to treat this circumstance as aggravating. It is the duty of every controller to comply with the law (including personal data protection regulations), so the lack of prior breaches cannot be a mitigating circumstance when imposing sanctions.

4. The manner in which the supervisory authority became aware of the breach (Article 83(2)(h) of Regulation 2016/679). The President of the UODO found a breach of the provisions of Regulation 2016/679 as a result of a notification of a personal data breach made by the Controller. By making this notification, the Controller was merely fulfilling a legal obligation, and there are no grounds to consider this circumstance as mitigating. According to the WP253 Guidelines, “The supervisory authority may become aware of a breach as a result of proceedings, complaints, articles in the press, anonymous tips, or notifications by the data controller. According to the regulation, the controller has an obligation to notify the supervisory authority of a personal data breach. The mere fulfillment of this obligation by the controller cannot be interpreted as a mitigating factor.”

5. Compliance with previously applied measures in the same case referred to in Article 58(2) of Regulation 2016/679 (Article 83(2)(i) of Regulation 2016/679). Prior to issuing this decision, the President of the UODO did not apply any of the measures listed in Article 58(2) of Regulation 2016/679 against the Controller in the case at hand, which means that the controller had no obligation to take any actions related to their application, and such actions, if assessed by the President of the UODO, could have a burdensome or mitigating impact on the assessment of the established breach.



6. The application of approved codes of conduct under Article 40 of Regulation 2016/679 or approved certification mechanisms under Article 42 of Regulation 2016/679 (Article 83(2)(j) of Regulation 2016/679). The Mayor does not apply approved codes of conduct or approved certification mechanisms referred to in the provisions of Regulation 2016/679. However, their adoption, implementation, and application are not - as stipulated by the provisions of Regulation 2016/679 - mandatory for controllers and processors, which means that the circumstance of their non-application cannot be considered against the Controller in this case. On the other hand, the circumstance of adopting and applying such instruments as measures guaranteeing a higher than standard level of protection for processed personal data could be taken into account in favor of the Controller.

7. Financial benefits obtained directly or indirectly in connection with the breach or losses avoided (Article 83(2)(k) of Regulation 2016/679). The President of the UODO did not find that the controller obtained any financial benefits or avoided such losses in connection with the breach. Therefore, there are no grounds to treat this circumstance as aggravating for the controller. The establishment of measurable financial benefits resulting from the breach of the provisions of Regulation 2016/679 would need to be assessed.

**\*\*Decidedly negative.** However, the failure of the administrator to achieve such benefits, as a natural state, independent of the violation and its consequences, is a circumstance that, by its very nature, cannot be mitigating for the Administrator. This is confirmed by the very wording of Article 83(2)(k) of Regulation 2016/679, which requires the supervisory authority to pay due attention to the benefits "achieved" - that occurred on the part of the entity committing the violation.**\*\***

8. **\*\*Other aggravating or mitigating factors (Article 83(2)(k) of Regulation 2016/679).****\*\*** The President of the Personal Data Protection Office (UODO), comprehensively considering the case, did not note any circumstances other than those described above that could affect the assessment of the violation and the amount of the imposed administrative monetary penalty. Taking into account all the circumstances discussed above, the President of the Personal Data Protection Office concluded that the imposition of an administrative monetary penalty on the Mayor is necessary and justified by the weight, nature, and scope of the violations attributed to the Mayor. It should be stated that the application of any other remedial measure provided for in Article 58(2) of Regulation 2016/679, particularly merely issuing a reprimand (Article 58(2)(b)), would not be proportional to the identified irregularities in the processing of personal data and would not guarantee that the Administrator would not commit further negligence in the future.

Referring to the amount of the administrative monetary penalty imposed on the Mayor, the President of UODO found that in the established circumstances of this case - i.e., due to the identification of violations of several provisions of Regulation 2016/679 (the principle of data confidentiality, expressed in Article 5(1)(f), as reflected in the obligations specified in Article 25(1) and Article 32(1) and (2) of Regulation 2016/679, and consequently also Article 5(2) of Regulation 2016/679 (the principle of accountability)) and the fact that the Mayor is an authority of a public finance sector entity - Article 102(1)(1) of the Act of May 10, 2018, on the protection of personal data (Journal of Laws of 2019, item 1781) applies, which results in a limitation on the amount (up to PLN 100,000) of the administrative monetary penalty that may be imposed on a public finance sector entity. In the opinion of the President of UODO, the administrative monetary penalty imposed serves, in the established circumstances of this case, the functions referred to in Article 83(1) of Regulation 2016/679, i.e., it will be effective, proportional, and deterrent in this individual case.

In the opinion of the President of UODO, the penalty imposed on the Mayor will be effective, as it will lead to a state in which the Mayor will apply such technical and organizational measures that ensure a level of security for the processed data corresponding to the risk of violation of the rights or freedoms of the individuals concerned and the severity of the threats accompanying the processes of processing that personal data. The effectiveness of the penalty is therefore equivalent to the guarantee that the Mayor, from the moment of the conclusion of this proceeding, will approach the requirements set by the data protection regulations with the utmost diligence.

The administrative monetary penalty imposed is also proportional to the identified violation, especially

its weight, effect, the circle of affected individuals, and the high risk of negative consequences that may arise in connection with the violation. In the opinion of the President of UODO, the administrative monetary penalty imposed on the Mayor will not constitute an excessive burden for him. The amount of the penalty has been set at a level that, on the one hand, constitutes an adequate response from the supervisory authority to the degree of violation of the administrator's obligations, while on the other hand, does not create a situation in which the necessity to pay it would lead to negative consequences in the form of a significant deterioration of the Administrator's financial situation. In the opinion of the President of UODO, the Mayor should and is able to bear the consequences of his negligence in the area of data protection, hence the imposition of a penalty in the amount of PLN 50,000 (fifty thousand zlotys) is fully justified.

In the opinion of the President of UODO, the administrative monetary penalty will serve, in these specific circumstances, a repressive function, as it will be a response to the Mayor's violation of the provisions of Regulation 2016/679, but also a preventive function, as it will contribute to preventing future violations of the Administrator's obligations arising from data protection regulations.

In the opinion of the President of UODO, the administrative monetary penalty imposed meets, in the established circumstances of this case, the criteria referred to in Article 83(1) of Regulation 2016/679 due to the weight of the identified violations in the context of the fundamental requirements and principles of Regulation 2016/679 - especially the principle of confidentiality expressed in Article 5(1)(f) of Regulation 2016/679. The purpose of the imposed penalty is to ensure that the Mayor complies with the provisions of Regulation 2016/679 in the future.

In this factual and legal state, the President of the Personal Data Protection Office has decided as stated in the operative part.

**\*\*Print Article\*\***

**\*\*Metadata\*\***

**\*\*Entity providing the information:\*\*** Department of Control and Violations

**\*\*Information created by:\*\*** Jan Nowak

**\*\*Date:\*\*** 2023-12-20

**\*\*Information entered by:\*\*** Wioletta Golańska

**\*\*Date:\*\*** 2024-03-22 10:20:39

**\*\*Last modified by:\*\*** Edyta Madziar

**\*\*Date:\*\*** 2024-05-24 11:06:37